Journal des décisions

Copie PDF de `docs/DECISIONS.md` au 16 octobre 2026 · 59 décisions, les plus récentes en haut · le fichier .md fait foi

Date	Décision	Raison	Alternative écartée
2026-10-16	Dépôt GitHub public, choisi par l'utilisateur ; commits signés de son adresse GitHub masquée (`…@users.noreply.github.com`) ; `A_LIRE/0_Etat_du_projet.pdf` (prénom, liens privés) et `_to_delete/` ignorés par git	aucune donnée personnelle dans le code, CI gratuite sans limite, mises à jour sans jeton GitHub sur le Mac (phase 5)	dépôt privé : minutes de CI limitées et jeton GitHub à stocker
2026-10-16	`goulot setup` ne demande les secrets d'alerte (jeton Telegram, mot de passe SMTP) que dans la section « Canal d'alerte », et seulement « Remplacer ? (o/N) » s'ils sont déjà dans le trousseau ; `goulot open --print` et `vault add-passkey --print` affichent le lien sans ouvrir le navigateur par défaut	le jeton était demandé deux fois ; Safari consommait le lien à usage unique avant qu'il soit collé dans Chrome	choisir le navigateur dans un réglage : plus lourd, même résultat
2026-10-16	Phase 1 : écoute sur `127.0.0.1` seul ; `localhost` se résout d'abord en `::1`, refusé aussitôt, puis `127.0.0.1` répond (36 ms à la première connexion, mesuré). `::1` ne sera ajouté (`GOULOT_BIND=127.0.0.1,::1`) que si Safari ou Chrome montre un délai réel	la règle 1 n'autorise `::1` que si un navigateur l'exige	écouter d'office sur `::1`
2026-10-16	En plus d'Origin et du jeton CSRF : refus de toute requête vers `/api/` ou `/auth/exchange` dont l'en-tête `Sec-Fetch-Site` n'est ni `same-origin` ni `none` ; corps limité à 1 Mo, longueur obligatoire sur POST, PUT et PATCH ; routes de documentation de FastAPI désactivées	défense en profondeur contre les pages servies sur d'autres ports de `localhost`, qui partagent les cookies	Origin seul
2026-10-16	Enrôlement d'une clé d'accès, échecs et blocage d'ouverture du coffre inscrits au journal de sécurité (`audit_log`) dès la phase 1 ; l'alerte Telegram ou e-mail correspondante part avec les alertes, en phase 3	le canal d'alerte n'existe pas encore	—
2026-10-16	Frontend : React 19.3.1, Vite 8.3.4, TypeScript 7.0.2, Vitest 5.0.5, versions exactes dans `package.json`, installation `--ignore-scripts` ; aucun script ni attribut `style` en ligne, pour tenir la CSP stricte sans exception	dernières versions stables ; CSP de `docs/SECURITY.md` inchangée	—
2026-10-16	CI : actions épinglées par commit (checkout v7.0.1, setup-uv v10.3.0, setup-node v7.1.0, gitleaks-action v2.3.9) ; pré-commit par un script versionné (`.githooks/pre-commit` : gitleaks puis ruff), sans le paquet `pre-commit`	aucune dépendance de plus	paquet `pre-commit`
2026-10-16	Tri par Claude Haiku 5.5 (`claude-haiku-5-5`), sans réflexion (`thinking: {"type": "disabled"}` , effort par défaut), validé par l'utilisateur ; tarifs ajoutés à `config/pricing.yaml` (0,10 $ / 0,50 $ par million de tokens jusqu'à 100 000 tokens de prompt, 0,50 $ / 2,50 $ au-delà ; Batch 0,05 $ / 0,25 $)	environ 10 fois moins cher que Haiku 4.5, sortie structurée prise en charge, cache dès 512 tokens au lieu de 4 096 ; tokenizer plus gourmand d'environ 30 %, largement compensé	Haiku 4.5 (`claude-haiku-4-5-20251001`)

2026-10-15	Dépendance directe `httpx2` (2.13, fork maintenu de `httpx`, publié par Pydantic) pour le client HTTP maison ; `httpx` ne reste qu'en dépendance de développement (client de test de FastAPI). Validé par l'utilisateur	le SDK `anthropic` 1.x n'accepte plus qu'un client `httpx2` : un seul transport à liste blanche sert ainsi le SDK et les sources	rester sur le SDK 0.x ; deux piles HTTP différentes
2026-10-15	Python 3.14 (version stable la plus récente avec des roues binaires pour toutes nos dépendances), installé par uv ; versions figées dans `uv.lock` : anthropic 1.15.0, fastapi 0.143.2, uvicorn 0.54.0, cryptography 50.0.2, webauthn 3.0.1, keyring 25.7.0, pydantic 2.14.1, apscheduler 3.11.3	Python 3.15.0 vient de sortir : risque de roues manquantes, alors que l'updater installe avec `--no-build`	Python 3.15
2026-10-15	Lanceur `./bin/goulot` dans la copie de travail (phases 1 à 4), qui exécute `uv run python -m goulot`	le projet n'est pas empaqueté (`package = false`) : `uv run goulot` n'a pas de point d'entrée ; le lanceur `~/.local/bin/goulot` arrive en phase 5	empaqueter le projet
2026-10-15	Jeton CSRF = HMAC-SHA-256 de l'identifiant de session avec un secret tiré au démarrage du serveur ; `goulot panic` révoque toutes les sessions, tous les jetons de lancement et de coffre, ce qui tient lieu de renouvellement du secret de session (sessions stockées sous forme d'empreinte, sans autre secret)	aucun jeton CSRF stocké, et un redémarrage invalide d'office les anciens jetons ; le frontend les redemande	jeton CSRF stocké en clair dans la base
2026-10-15	Enrôlement de la première clé d'accès : la clé de secours se tape dans le Terminal (`goulot vault add-passkey`, aussi proposé par `goulot setup`), qui délivre un lien d'enrôlement à usage unique valable 10 minutes ; la page du navigateur ne voit jamais la clé de secours	la clé de secours ne doit être saisie que dans le Terminal (consigne de l'utilisateur)	saisie de la clé de secours dans la page web
2026-10-15	Cookie de session sans attribut `Secure`	l'interface est en `http://localhost` : Safari refuse les cookies `Secure` sur HTTP ; `HttpOnly` et `SameSite=Strict` restent	`Secure` : session impossible dans Safari
2026-10-15	API Claude vérifiée le 15 octobre 2026 : identifiants `claude-haiku-4-5-20251001` et `claude-sonnet-5-5` valides ; `web_search_20260318` existe (filtrage dynamique par défaut, paramètre `response_inclusion` en plus) ; `output_config.format` accepté par Haiku 4.5 et Sonnet 5.5, limites conformes (24 champs optionnels, 16 unions, `minItems` 0 ou 1, casse des énumérations non garantie) ; sur Sonnet 5.5, `thinking: {"type": "disabled"}` renvoie 400 et `between_tools` n'accepte aucun autre champ ni d'effort au-delà de `high` (la synthèse en `medium` est conforme) ; Haiku 4.5 : ni réflexion adaptative ni `effort` (le tri n'en envoie pas) ; cache d'une heure par `ttl: "1h"` sans en-tête bêta, minimum 512 tokens sur Sonnet 5.5 et 4 096 sur Haiku 4.5 ; Batch : remise de 50 %, expiration à 24 h, résultats gardés 29 jours, recherche web facturée comme en standard	contrôle demandé avant de coder	—

2026-10-15	Écart de tarif corrigé dans `config/pricing.yaml` : lecture du cache de Sonnet 5.5 à 0,10 $ par million de tokens (0,05 × l'entrée), et non 0,20 $; les autres tarifs relevés le 3 octobre sont confirmés	le compteur de coût en dépend	—
2026-10-15	Refus (`stop_reason: "refusal"`) traités comme un échec de l'appel, journalisé sans contenu, sans repli automatique sur un autre modèle (paramètre `fallbacks` non utilisé)	un repli changerait de modèle et de coût sans passer par le budget ; le verdict reste calculé sans cette analyse	repli serveur `fallbacks: "default"`
2026-10-15	Sources vérifiées depuis l'extérieur le 15 octobre 2026 (à revérifier depuis le Mac en phase 3) : PubChem PUG REST, GDELT DOC 2.0 (250 articles au plus, fenêtre de 3 mois), Google News RSS (élément `<source url>` présent), GDACS RSS, USGS GeoJSON, NASA FIRMS (5 000 transactions par 10 min ; la clé est dans le chemin de l'URL), NOAA NHC (`index-at.xml`, `index-ep.xml`), IMF PortWatch, PEGELONLINE (station KAUB), Eurostat (`sts_inpp_m`), NBS (communiqués décadaires), BLS (500 requêtes par jour) répondent. Écarts : Bourse de Guangzhou (GFEX) servie avec un certificat HTTPS d'un autre domaine, donc désactivée ; Bourse de Zhengzhou refuse les requêtes automatisées (HTTP 412), à retester depuis le Mac ; douanes américaines : clé désormais obligatoire (`key:census`) ; ReliefWeb : nom d'application pré-approuvé obligatoire depuis novembre 2025, source désactivée jusqu'à l'accord ; EIA : la clé passe obligatoirement dans l'URL (`api_key=`), d'où l'expurgation des URL dans les journaux ; ECICS : pas d'API, mais un téléchargement complet de la base, préféré à la consultation page par page ; eMARS : géré par l'Agence européenne pour l'environnement depuis janvier 2026 ; Banque mondiale : fichier mensuel sur `thedocs.worldbank.org` ; OFAC : listes sur `sanctionslist.ofac.treas.gov` ; Federal Register : page protégée contre les robots, à retester depuis le Mac	`config/sources.yaml` remplace `sources.example.yaml`, avec un champ `enabled`	garder les points d'accès non vérifiés
2026-10-07	Prix : sources officielles et gratuites d'abord, dans un ordre fixe (cotation des bourses chinoises et de l'EIA, prix officiels chinois tous les 10 jours, prix douaniers unitaires par code SH, indices BLS et Eurostat, indice des intrants) ; Yahoo et Stooq relégués au dépannage	ces sources couvrent la chimie de base et les grands repères, avec un historique long et des conditions claires ; un prix douanier existe pour presque tout CAS	Yahoo et Stooq en premier rang : non officiels, fragiles, inutilisables pour une version vendue
2026-10-07	Bibliothèque de cas comparables : cas préparés par l'IA avec sources, vérifiés par l'utilisateur ; réaction des prix calculée par le code (variation propre, hors facteur de marché) ; nombre de cas et fourchette toujours affichés, « pas assez de cas » sous 3	l'ampleur d'une hausse est l'estimation la plus fragile de l'IA ; des réactions mesurées, vérifiables par chacun, l'ancrent	ampleurs estimées par l'IA seule ; variations de prix rapportées par l'IA depuis ses sources
2026-10-07	Pression de prix de −2 à +2 pour toute matière, même sans cotation ; pourcentage seulement depuis une hypothèse ou des cas comparables ; résultat noté au registre sur la meilleure série disponible	l'utilisateur veut une tendance même sans prix de base ; la baisse est aussi un conseil (« pas d'urgence à acheter ») ; une tendance doit rester vérifiable	pas de tendance sans cotation ; pourcentage sur un prix de base inconnu
2026-10-07	Marge (prix moins coût des intrants) comme signal de tension propre à la matière	distingue une pénurie d'une simple hausse des coûts	indice des intrants seul

2026-10-07	Exclus : EM-DAT, sites de prix chinois protégés contre la collecte (SunSirs, 100ppi, Echemi), bases payantes (ICIS, Argus, Platts)	EM-DAT est réservé aux organismes de recherche et interdit d'usage commercial ; collecter un site qui le refuse est fragile et contraire à ses conditions	les intégrer quand même
2026-10-05	Verdict personnel : sévérité relevée selon l'exposition (`s_perso` au moins 2 dès 10 % du volume, au moins 3 dès 50 %) pour un événement perturbant sur ses chemins	la sévérité de l'IA mesure le marché : un fournisseur petit mais essentiel y vaut 0 ou 1, et la règle physique ne se déclenchait jamais pour lui (relecture indépendante)	sévérité du marché seule
2026-10-05	Alertes et vue coffre fermé : verdict personnel limité au libellé et à la fenêtre d'action, sans X ; événements privés jamais annoncés comme « nouvel événement »	X et la fenêtre d'action ensemble révèlent le délai contractuel ; un signal privé alerté en détail fuirait par Telegram ou l'e-mail	X et fenêtre d'action partout
2026-10-05	Retour arrière sans perte du registre ni des saisies (export puis réinscription à l'identique) ; migrations additives ; données associées du chiffrement fondées sur des noms logiques et des UUID	restaurer une sauvegarde effaçait des entrées du registre, déjà ancrées dans une synthèse, et des signaux saisis à la main ; un `VACUUM` ou une migration auraient rendu des champs indéchiffrables	restauration brute ; données associées sur table, colonne et `rowid`
2026-10-05	Clé de secours retapée en entier avec caractère de contrôle, renouvelable ; sauvegarde Time Machine chiffrée exigée	une faute de frappe non détectée ou une sauvegarde restée sur le Mac rendraient la clé inutile le jour où elle sert ; le trousseau sauvegardé n'est protégé que par le mot de passe du Mac	confirmation d'un seul groupe ; sauvegardes locales seules
2026-10-05	Coffre complet (chiffrement, Touch ID, jeton de coffre) dès la phase 1 ; jeton prolongé seulement par les actions de l'utilisateur, durée absolue 8 h	la couverture est saisie dès la phase 2 ; l'interrogation périodique de l'interface aurait gardé le coffre ouvert indéfiniment	Touch ID en phase 4 ; expiration glissante sur toute requête
2026-10-05	« Ma chaîne » : chaîne réelle de l'utilisateur en surimpression de la chaîne type ; risque physique sur ses chemins, prix sur le marché ; un site qui pèse au moins 10 % de son volume déclenche l'analyse	la chaîne type est une moyenne : un fournisseur absent n'était jamais surveillé, un petit fournisseur unique ne déclenchait aucune analyse (seuil de 0,5 % de l'offre mondiale), et une panne hors de ses chemins pouvait déclencher une alerte physique	corriger la chaîne type à la main : données en clair, sans part de volume ni chemin propre à l'utilisateur
2026-10-05	L'IA juge le marché, le Mac juge l'exposition : rapprochement avec Ma chaîne, exposition et verdict personnel calculés localement ; la synthèse rédigée par l'IA reçoit le verdict marché	aucune donnée privée n'a besoin de quitter le Mac ; le même découpage permettra une version hébergée chiffrée de bout en bout	envoyer Ma chaîne à l'IA, même pseudonymisée : fuite par recoupement, et inutile
2026-10-05	Coffre : données privées chiffrées en AES-256-GCM, clé maîtresse dans le trousseau, clé de secours imprimée, ouverture par clé d'accès WebAuthn (Touch ID) ; mode standard dans le MVP, mode renforcé (clé enveloppée grâce à l'extension PRF) après	le chiffrement seul ne protège pas un tableau de bord ouvert, puisque l'app déchiffre pour afficher : le coffre arrête un intrus devant l'écran, le chiffrement protège le disque et les sauvegardes ; le mode standard garde des alertes précises en arrière-plan	SQLCipher (base entière chiffrée, roues binaires incertaines avec `--no-build`, et la veille aurait besoin de la clé pour tout) ; phrase de passe à retenir ; Touch ID natif par PyObjC (simple contrôle logique, sans lien avec l'origine de la page)

2026-10-05	Interface servie sur `http://localhost:8742` au lieu de `http://127.0.0.1:8742`	WebAuthn refuse les adresses IP comme identifiant de site ; Chromium accepte les pages HTTP servies depuis `localhost` (documentation « Origins that support WebAuthn ») ; le serveur reste sur l'interface de bouclage	garder `127.0.0.1` : pas de Touch ID possible
2026-10-05	Dépendance `webauthn` (Duo Labs, version 3.0.1 de septembre 2026 au moment de la décision)	bibliothèque de référence pour vérifier les signatures WebAuthn, maintenue ; elle tire `cbor2`, `pyasn1`, `pyasn1-modules` et `pyOpenSSL`	vérification écrite à la main : trop risqué
2026-10-05	Résultats « non résolus » et « résolus sur indice », série privée (devis, achats, signaux) ; colonnes « Marché » et « Ma matière » ; 90 jours de rodage	sans prix public, le silence comptait comme une réussite, et l'indice proxy mesure les intrants, pas la spécialité ; un test sur des crises passées est faussé puisque le modèle connaît l'issue	compter le silence comme une réussite ; publier des taux de réussite dès le premier mois
2026-10-05	Empreinte à clé (HMAC-SHA-256) des entrées du calcul ; empreinte des entrées du registre calculée sur le chiffré des champs privés	une empreinte simple laissait retrouver stock, délai et seuil en essayant toutes les combinaisons	SHA-256 simple
2026-10-05	Signal fournisseur en un tap, compté dans le verdict personnel et dans les résultats	les lettres des fournisseurs (hausse, allocation, force majeure) arrivent avant la presse, et forment la meilleure vérité terrain	se fier à la seule presse
2026-10-05	« Rien à signaler » seulement si un cycle de collecte a réussi depuis moins de 12 h ; alerte de vie externe facultative	un Mac éteint ou une clé expirée ne doivent pas ressembler à un calme plat	aucun contrôle de fraîcheur
2026-10-05	Réserve de crise à 90 % du plafond de veille, et proposition de relever le plafond pendant un événement grave	le plafond ne doit pas couper l'IA au moment où elle sert le plus	plafond fixe sans réserve
2026-10-05	Localisation des sites privés hors ligne (villes GeoNames) ; niveau de surveillance en ligne par site : aléas seulement, ville et matière (par défaut), ou ville, matière et entreprise ; règles privées jamais stockées	un géocodeur en ligne ou une requête nominative révéleraient la liste des fournisseurs ; la ville seule garde un bon rappel sans nommer personne	géocodage Nominatim ; requêtes nominatives par défaut ; aucune requête pour les sites privés
2026-10-05	Coffre en phase 1 ; Ma chaîne en phase 4 ; mises à jour en phase 5 ; export de conformité en phase 6	Ma chaîne corrige le plus gros point faible et sert l'usage quotidien ; aucune donnée privée ne doit exister en clair ni sans coffre, même un temps	Ma chaîne après l'export de conformité
2026-10-04	Registre des conseils en ajout seul, chaîné par empreintes et ancré chaque semaine ; écran Fiabilité montrant le prix réel et chaque conseil daté avec sa fourchette en éventail	la fiabilité doit être vérifiable et ne jamais s'embellir après coup ; Goulot ne prévoit pas une trajectoire de prix, il émet des conseils datés avec des fourchettes	courbe de « prix anticipé » superposée au prix réel : elle montrerait une prévision que Goulot n'a jamais faite ; tableau seul, sans graphique
2026-10-04	Export de conformité sur le modèle de l'article 24 du règlement (UE) 2024/1252, produit localement, sans IA	répond à une obligation, donc à un budget, et sert de preuve de sérieux ; un texte réglementaire ne doit pas être rédigé par un modèle	pas d'export ; rapport rédigé par l'IA
2026-10-04	Chaque release est approuvée par l'utilisateur (un tap dans l'app GitHub), construite sans secret et signée dans un job isolé ; dépôt public recommandé	aucune version n'atteint le Mac sans décision humaine ; protections gratuites sur un dépôt public	publication et installation entièrement automatiques : du code jamais vu par personne arriverait sur le Mac ; dépôt privé gratuit : ni protection de branche ni approbation

2026-10-04	Dependabot avec 7 jours de recul (`cooldown`), correctifs de sécurité non retardés	la plupart des versions piégées sont repérées et retirées en quelques jours	adoption immédiate des nouvelles versions
2026-10-04	Clés de confiance de l'updater uniquement dans `trust.py`, livré dans les versions signées	une clé ajoutée par un fichier modifiable serait une porte dérobée	dossier de clés sur le disque
2026-10-04	« Confirmé » exige au moins une source de fiabilité ≥ 0,7 ; domaines classés dans `config/reliability.yaml`	quelques faux sites ne doivent pas pouvoir déclencher une alerte	seuil de `c_fait` seul
2026-10-04	Prix appelés directement par le client maison, sans `yfinance` ni `akshare`	ces bibliothèques font leurs propres appels réseau, hors liste blanche	bibliothèques tierces
2026-10-04	Bac à sable de Claude Code activé pour la construction	les règles de permission seules ne protègent pas les clés : les tests exécutent du code arbitraire	permissions seules
2026-10-04	Graphe de chaîne orienté de l'amont vers la matière achetée, seul maillon final ; URL des sources gardées par le code, jamais écrites par l'IA	le délai X se calcule par plus court chemin jusqu'à la matière ; aucun lien inventé ou piégé ne peut apparaître dans l'interface	graphe sans sens imposé : délais incalculables ; URL produites par le modèle : risque d'hallucination et d'injection
2026-10-04	Mises à jour automatiques par releases GitHub signées (Ed25519), vérifiées puis testées sur le Mac, avec retour arrière	une mise à jour ne doit jamais devenir une porte d'entrée	`git pull` direct sur l'installation : pas de vérification d'intégrité ni de retour arrière propre
2026-10-04	Accès à l'interface par lien à usage unique puis cookie de session	protège contre les autres logiciels du Mac et les sites malveillants, sans mot de passe à retenir	aucune authentification sur localhost : vulnérable au CSRF et au DNS rebinding
2026-10-04	Secrets dans le trousseau macOS via `keyring`	chiffré par le système, jamais en clair sur le disque	fichier `.env`
2026-10-04	Plafond IA : veille 5 $ par mois, reconstructions 10 $ par mois avec devis, limite dure 15 $ sur l'espace de travail Anthropic « goulot »	le moins cher possible sans perdre la qualité des verdicts ; environ deux fois la dépense attendue pour 3 matières	pas de plafond, ou plafond trop bas qui priverait d'analyse au moment d'une crise
2026-10-04	Reconstruction en deux appels : recherche web, puis structuration JSON	les sorties structurées sont incompatibles avec les citations de la recherche web	un seul appel avec sortie structurée : rejeté par l'API
2026-10-04	Tri par Claude Haiku 4.5, analyse par Claude Sonnet 5.5, en Batch	meilleur compromis qualité-prix ; environ 2,20 $ par mois pour 3 matières	Opus 5.5 pour tout : 2 fois plus cher ; modèle local : reporté après le MVP
2026-10-04	Installation sur le Mac de l'utilisateur, sans serveur	coût d'hébergement nul ; la veille rattrape son retard au réveil du Mac	serveur loué (5,49 € HT par mois) : envisageable plus tard pour des alertes 24 h sur 24
2026-10-04	Carte 2D MapLibre et OpenFreeMap	gratuite, sans clé, légère	globe 3D God's Eye View : reporté après le MVP
2026-10-04	Alertes Telegram ou e-mail au choix	demandé par l'utilisateur	notifications macOS : invisibles hors du Mac
2026-10-04	Usage achats ; stock et délai fournisseur facultatifs	demandé par l'utilisateur	—